Controles para mitigar riesgos de confidencialidad en Oracle

Identificación académica

Estudiante: Efrain Retana Segura. **Institución:** Universidad Nacional, Facultad de Ciencias Exactas y Naturales, Escuela de Informática. **Curso:** EIF402 Administración de Bases de Datos, II Ciclo 2026. **Docente:** Johnny Villalobos Murillo. **Fecha:** 28 de octubre de 2026.

Resumen

Este proyecto diseña un laboratorio para gestionar riesgos de confidencialidad en Oracle Database 21c XE. El sitio R-CONF relaciona riesgos, controles seleccionados de ISO/IEC 27001:2022 e ISO/IEC 27002:2022, PHVA, mínimo privilegio y evidencia técnica. Una instalación en XEPDB1 permite mostrar cuentas separadas, vistas de alcance limitado, un paquete PL/SQL, políticas de auditoría y pruebas positivas y negativas. Las salidas compartidas por el estudiante son compatibles con la denegación de tablas base en T07 y T08. T11 continúa abierto porque una entrada de auditoría con código de retorno 0 aún debe correlacionarse. Los demás controles se presentan como propuestas o pendientes de comprobación; no se afirma cumplimiento, auditoría certificada ni despliegue Azure.

Objetivo general y alcance

Objetivo general: diseñar e implementar un laboratorio académico de controles orientados a mitigar riesgos de confidencialidad asociados a Oracle, con referencia a ISO/IEC 27001:2022 e ISO/IEC 27002:2022, aplicando PHVA y mínimo privilegio, y establecer pruebas y evidencias que permitan valorar los resultados.

Se analiza la lectura o revelación no autorizada en cuentas Oracle, vistas, operaciones de la aplicación, secretos, canales de red, logs, exportaciones y copias de respaldo. Los datos de demostración son sintéticos. Integridad y disponibilidad se consideran solo cuando ayudan a resguardar la confidencialidad.

El sitio ofrece modo de demostración y modo Oracle. La demostración conserva datos de ejemplo en el navegador y no acredita controles. El modo Oracle usa una API Flask y una cuenta técnica con privilegios limitados. El artefacto interactivo local se abre en `http://127.0.0.1:8000/#controls`; el código está en `https://github.com/EfrainR06/rconf-oracle-iso27001`. El prototipo no constituye un SGSI completo, una Declaración de Aplicabilidad (SoA) integral, una evaluación jurídica, una auditoría independiente ni una certificación ISO. Azure queda planificado; el despliegue aún no se realizó.

Marco teórico

2013 frente a 2022

ISO/IEC 27001 especifica requisitos para establecer, operar, evaluar y mejorar un sistema de gestión de seguridad de la información (SGSI). ISO/IEC 27002 proporciona guía de selección e implementación de controles; no sustituye los requisitos de 27001 ni define por sí sola la certificación (International Organization for Standardization [ISO], 2013a, 2013b, 2022a, 2022b).

La edición 2013 de ISO/IEC 27002 agrupaba 114 controles en 14 dominios. La edición 2022 reorganiza 93 controles en cuatro temas: organizacional, personas, físico y tecnológico. Parte de la diferencia corresponde a fusiones, actualización de alcance y redacción; la cifra menor no significa que se hayan retirado sin más 21 medidas. La edición 2022 añadió once controles, incluidos seguridad en nube (5.23), gestión de configuración (8.9), eliminación (8.10), enmascaramiento (8.11), prevención de fuga (8.12), monitoreo (8.16) y codificación segura

(8.28). También introdujo cinco atributos para filtrar los controles y correspondencias con la edición anterior (ISO/IEC JTC 1/SC 27, 2022).

ISO/IEC 27001:2022 mantiene el enfoque basado en riesgos e incorpora, entre otros cambios, el requisito 6.3 para planificar cambios del SGSI. El principio de mínimo privilegio no apareció por primera vez en 2022: ya tenía correspondencias en controles de acceso de 2013. En 2022 se relaciona especialmente con 5.15–5.18, 8.2 y 8.3. Las equivalencias no siempre son uno a uno; las referencias de este proyecto son orientativas, no sustituyen el texto normativo ni una SoA.

Confidencialidad, privilegio mínimo y defensa en profundidad

La confidencialidad busca impedir que información sea revelada a personas, procesos o entidades no autorizadas. El mínimo privilegio limita cada cuenta a los datos y operaciones necesarios para una función aprobada. En Oracle se traduce en identidades con dueño claro, roles separados, concesiones explícitas y revisión de privilegios directos e indirectos. `RCONF_APP` puede consultar vistas y ejecutar un paquete de aplicación; no debe recibir DBA, `SELECT ANY TABLE` ni acceso directo a tablas sensibles. Las pruebas positivas comprueban que la función autorizada opera y las negativas verifican que los accesos innecesarios sean denegados (Oracle, 2021a).

La defensa en profundidad combina capas: autenticación y autorización; vistas o interfaces limitadas; cifrado en tránsito y en reposo cuando corresponda; auditoría; protección de respaldos; gestión de secretos y revisión humana. El enfoque Zero Trust puede orientar la comprobación explícita de identidad, contexto y autorización, pero no se atribuye a una cláusula ISO específica ni se considera habilitado por el prototipo.

Opciones Oracle y límites de los mecanismos

Una vista que sustituye datos sintéticos permite demostrar reducción de columnas y denegación de tablas base. No equivale a Oracle Data Redaction ni acredita anonimización. Oracle Virtual Private Database puede aplicar políticas de fila y columna en entornos compatibles. TDE protege archivos de datos seleccionados en reposo; la red, los respaldos y la gestión de claves requieren decisiones y comprobaciones separadas. Data Redaction, TDE y Database Vault pueden depender de edición, opción o licencia; su disponibilidad no se infiere de Oracle XE. Para datos en tránsito debe validarse configuración de cifrado e integridad de Oracle Net, TLS/TCPS y certificados, además de limitar listener y rutas de red (Oracle, 2021b, 2021c, 2021d).

El cifrado no reemplaza al control de acceso. Las copias RMAN deben revisar cifrado, repositorio y custodia de claves, y demostrar restauración; Oracle documenta la columna `ENCRYPTED` en `V$BACKUP_PIECE` para revisar el estado de cada pieza (Oracle, 2021h, 2021j). Los registros de auditoría requieren retención, acceso restringido, correlación y revisión; la vista `AUDIT_UNIFIED_ENABLED_POLICIES` informa las políticas habilitadas y `UNIFIED_AUDIT_TRAIL` conserva eventos (Oracle, 2021d, 2021g, 2021i). Un SIEM o DLP empresarial no forma parte del prototipo. Las exportaciones y los clones DEV/TEST deben evitar datos reales en claro y conservar aprobación y sanitización.

Contexto costarricense

La Ley N.º 8968 y su reglamento regulan la protección de datos personales y el derecho a la autodeterminación informativa en Costa Rica (Asamblea Legislativa de la República de Costa Rica, 2011; Poder Ejecutivo de Costa Rica, 2012). Este proyecto traduce el tema a prácticas técnicas de confidencialidad; no determina por sí solo la base jurídica, obligaciones de una organización, plazos de retención o requisitos de consentimiento. La aplicabilidad legal debe verificarse según el contexto y con la orientación del curso o personal competente.

Método de valoración y riesgos R-CONF

La matriz usa una escala ordinal de probabilidad (P) e impacto (I) de 1 a 5; el producto P × I es un criterio interno del laboratorio, no una fórmula prescrita por ISO. Los intervalos son: 1–4 bajo, 5–9 medio, 10–16 alto y 17–25 crítico. Los números describen hipótesis educativas; los residuales son estimaciones objetivo y no reducciones empíricamente medidas.

- **R-CONF-01 — Permisos excesivos en cuentas de aplicación.** Activo: esquema de clientes; escenario: cuenta comprometida con lectura amplia. Inherente P4 × I5 = 20, crítico. Residual objetivo P2 × I5 = 10, alto. Responsable: DBA. Tratamiento: roles mínimos, vistas y paquete; pruebas de lectura permitida, tabla base denegada y ausencia de privilegios ANY.
- **R-CONF-02 — Cuentas activas sin necesidad vigente.** Activo: identidades Oracle; escenario: acceso de una cuenta fuera de función. Inherente P3 × I4 = 12, alto. Residual objetivo P1 × I4 = 4, bajo. Responsable: dueño de accesos. Tratamiento: revisión periódica, justificación y bloqueo de cuentas sobrantes.
- **R-CONF-03 — Credenciales en código o repositorios.** Activo: secretos de conexión; escenario: credencial reutilizada por acceso al código. Inherente P4 × I5 = 20, crítico. Residual objetivo P1 × I5 = 5, medio. Responsable: desarrollo/DBA. Tratamiento: rotación, secretos fuera del repositorio y control de acceso al almacén.
- **R-CONF-04 — Tráfico de base de datos desprotegido.** Activo: canal aplicación–Oracle/Azure; escenario: interceptación o conexión no autorizada. Inherente P3 × I5 = 15, alto. Residual objetivo P1 × I5 = 5, medio. Responsable: red. Tratamiento: rutas restringidas, TCPS/TLS y validación de certificado.
- **R-CONF-05 — Lectura innecesaria de datos personales.** Activo: datos sintéticos de clientes; escenario: usuario técnico accede a campos fuera de su necesidad. Inherente P4 × I4 = 16, alto. Residual objetivo P1 × I4 = 4, bajo. Responsable: dueño del dato. Tratamiento: reducir columnas, vista enmascarada de demostración y denegación de tabla base.

R-CONF-06 corresponde a exportaciones y evidencias; R-CONF-07, a lectura sin rastro; R-CONF-08, a respaldos legibles por terceros. El registro web contiene ocho escenarios. Para el análisis, un residual mayor a 4 continúa en tratamiento; cualquier aceptación requiere decisión motivada del gestor y evidencia revisada.

12 tareas DBA relacionadas con confidencialidad

1. **Usuarios:** inventariar cuentas, dueños, altas, bajas, bloqueos y necesidad vigente.
2. **Privilegios:** revisar grants directos, roles heredados, permisos ANY y PUBLIC; separar owner, app y auditor.
3. **Autenticación:** revisar perfiles, administración de credenciales y rotación; nunca guardar secretos en el repositorio.
4. **TDE:** evaluar si se requiere, si la edición/licencia lo permite y cómo se custodiarán claves; no asumir habilitación en XE.
5. **Enmascaramiento:** usar datos sintéticos o vistas; evaluar Data Redaction/VPD solo tras comprobar soporte/licencia.
6. **Respaldos:** restringir archivos, cifrar cuando sea compatible, separar claves y comprobar restauración.
7. **Auditoría:** configurar eventos, revisar Unified Audit Trail, correlacionar y escalar anomalías.
8. **Parches:** comparar versión y `DBA_REGISTRY_SQLPATCH` con línea base y registrar cambios.
9. **Listener/red:** restringir orígenes y puertos, revisar configuración y evaluar TLS/TCPS.
10. **Eliminación:** aprobar retención y borrado seguro de datos, copias y exportaciones; la papelera es solo señal parcial.
11. **Logs:** limitar lectura/escritura/borrado, aplicar retención y revisar cambios y accesos.
12. **Clones DEV/TEST:** documentar aprobación, sanitizar antes de habilitar usuarios y evitar datos productivos en claro.

Selección de los 15 controles requeridos

La asignación solicita justificar los siguientes controles del Anexo A de 27001:2022 y guiarse por 27002:2022. Las correspondencias a 2013 son aproximadas y deben contrastarse con la versión normativa disponible.

- **5.12 Clasificación de la información** (relación orientativa: A.8.2.1/A.8.2.2): inventario, nivel de sensibilidad y reglas de manejo; evidencia esperada: catálogo de datos y aprobación.
- **5.15 Control de acceso** (A.9.1.1/A.9.1.2): matriz de roles y necesidad de conocer; evidencia: autorizaciones y revisión.
- **5.16 Gestión de identidades** (A.9.2.1): ciclo de vida de cuentas; evidencia: altas/cambios/bajas y DBA_USERS.
- **5.17 Información de autenticación** (A.9.2.4 y controles relacionados): proteger, distribuir y rotar secretos; evidencia: proceso y registro sin divulgar claves.
- **5.18 Derechos de acceso** (A.9.2.2/A.9.2.5/A.9.2.6): aprobar, revisar y revocar concesiones; evidencia: comparación de privilegios.
- **5.33 Protección de registros** (A.18.1.3): proteger registros y expediente; evidencia: permisos, retención y responsable.
- **8.2 Derechos de acceso privilegiado** (A.9.2.3): separar tareas DBA, owner, app y revisión; evidencia: DBA_SYS_PRIVS y DBA_ROLE_PRIVS.
- **8.3 Restricción de acceso a la información** (A.9.4.1): exponer vistas/paquete y denegar tablas base; evidencia: prueba positiva y negativa.
- **8.5 Autenticación segura** (A.9.4.2/A.9.4.3): proteger autenticación y perfiles; evidencia: revisión de DBA_USERS/DBA_PROFILES y procedimiento de secretos.
- **8.10 Eliminación de información** (nuevo en 2022): definir ciclo de vida y borrado de exportaciones/copias; evidencia: política y acta.
- **8.11 Enmascaramiento de datos** (nuevo en 2022): limitar o sustituir datos de prueba; evidencia: vista sintética y prueba de acceso.
- **8.12 Prevención de fuga de datos** (nuevo en 2022): restringir exportaciones y destinos; evidencia: política, permisos y registros de revisión.
- **8.13 Respaldo de la información** (A.12.3.1): restringir y verificar copias; evidencia: RMAN, cifrado, custodia y restauración.
- **8.15 Registro de eventos** (A.12.4.1–A.12.4.3): registrar accesos y cambios pertinentes; evidencia: políticas y Unified Audit Trail.
- **8.20 Seguridad de redes** (A.13.1.1–A.13.1.3): proteger listener, rutas y tráfico; evidencia: configuración, reglas y servicio cifrado.

El sitio incluye una matriz de madurez inicial 0–4 para esos 15 controles, con evidencia disponible, estado (Cumple/No cumple/Parcial) y prueba vinculada. La autoevaluación conservadora marca controles como No cumple o Parcial mientras falte evidencia. No hay control clasificado como Cumple; los puntajes representan evidencia del laboratorio, no cumplimiento corporativo. Cinco controles complementarios del catálogo son 5.23, 8.9, 8.16, 8.24 y 8.28.

PHVA, implementación y verificación

Planificar: definir contexto, activos, amenaza, P/I, responsable y tratamiento. **Hacer:** instalar cuentas, roles, vistas, paquete y auditoría con el script correspondiente en XEPDB1. **Verificar:** ejecutar pruebas como la cuenta a la que aplica el permiso y revisar el catálogo/auditoría como DBA. **Actuar:** corregir, asignar revisor y fecha, y solo entonces documentar aceptación o reducción residual. La correspondencia PHVA con cláusulas 4–10 se usa como recurso pedagógico y no como interpretación normativa literal.

La cuenta de aplicación no tiene permiso para tablas base. Las transcripciones compartidas por el estudiante indican que `MASKED_PERSONAL` devolvió una etiqueta sintética y correo `[oculto]`, y que las consultas directas a `DEMO_PERSONAL` y `RISKS` fueron denegadas. El script `05_verify_runtime.sql` también informó denegación a UPDATE directo. Estas salidas son evidencia aportada, pendiente de revisión independiente y de conservar en archivos originales.

La política `RCONF_ACCESS_POLICY` se informó habilitada. T11 mostró eventos para `DEMO_PERSONAL` con códigos 2004 y 0. Se mantiene abierto hasta correlacionar cada registro por usuario, sesión, hora y sentencia; no se interpreta el código 0 como lectura no autorizada confirmada.

Se incluye `sql/08_auditor_controls.sql`, conjunto de consultas DBA de solo lectura para revisar permisos, cuentas, perfiles, auditoría, objetos, respaldos, red y parches. No reemplaza pruebas de runtime ni modifica la base. La matriz web enumera 15 pruebas de auditoría externa con procedimiento, resultado esperado, herramienta y estado; solo T07/T08 se marcan como observadas según salida compartida, y T11 queda pendiente. El informe y el plan de validación contienen los pasos y límites.

Conclusión y trabajo pendiente

El diseño vincula escenarios de confidencialidad con controles de acceso, tareas DBA y pruebas repetibles. Los resultados compartidos respaldan de manera preliminar la restricción de tablas base en el laboratorio. No prueban los controles de clasificación, retención, fuga, respaldo, cifrado de red, parches ni clon DEV/TEST; tampoco resuelven T11. Para cerrar la entrega, el estudiante debe reproducir las pruebas, conservar los spools originales, revisar puntuaciones y referencias, completar la correlación de auditoría, firmar su propia declaración de uso de IA y grabar el video de cinco minutos indicado por la asignación. No se declara publicada la aplicación en Azure.

El uso de Codex, sus contribuciones y las validaciones pendientes se documentan en `04_uso_ia.md`, sin reproducir conversaciones privadas. Las fuentes en formato APA 7 se listan en `06_fuentes.md`.

Tabla de uso de IA para completar y revisar

El registro describe la asistencia recibida, sin transcribir conversaciones privadas. La columna de prompt exacto requiere completar el registro real; los ejemplos ficticios no la sustituyen.

Herramienta IA	Prompt Exacto Utilizado	Aporte de la IA	Validación / Corrección del Estudiante	Fuente Verificada
OpenAI Codex	Pendiente de incorporación por el estudiante desde su registro real.	Propuesta y elaboración sustancial de interfaz, API y documentación.	Pendiente de revisión personal y constancia del estudiante.	Fichas oficiales ISO/IEC 27001:2022 y 27002:2022, consultadas por la asistencia; cotejo del estudiante pendiente.
OpenAI Codex	Pendiente de incorporación por el estudiante desde su registro real.	Scripts de cuentas, permisos, vistas, auditoría y ensayo aislado antes/después.	Repetir pruebas, guardar spools y registrar correcciones. El nuevo ensayo 11–17 está preparado, pendiente de ejecución.	Oracle Database 21c Security Guide y Database Reference; cotejo personal pendiente.

Herramienta IA	Prompt Exacto Utilizado	Aporte de la IA	Validación / Corrección del Estudiante	Fuente Verificada
OpenAI Codex	Pendiente de incorporación por el estudiante desde su registro real.	Comparativa 2013/2022, selección de controles, matriz y guía de pruebas.	Revisar correspondencias, valoración de riesgos y niveles de madurez; firmar solo tras validarlos.	ISO/IEC JTC 1/SC 27 (2022) y documentos del curso; consultar referencias APA.

Declaración jurada — borrador sin firmar

Texto propuesto para que el estudiante lo revise y firme únicamente después de completar la tabla real y validar el contenido. Los ejemplos ficticios anteriores no constituyen el registro de uso real.

Yo, Efrain Retana Segura, declaro que todo contenido generado con IA ha sido declarado en la tabla de uso real, validado contra fuentes oficiales (ISO y documentación del motor de bases de datos) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

Nombre: Efrain Retana Segura

Firma del estudiante: _____

Fecha: _____

Estado: sin firma; registro de prompts y revisión personal pendientes. La herramienta no firma ni certifica esta declaración en nombre del estudiante.

Referencias del documento

Asamblea Legislativa de la República de Costa Rica. (2011). Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales (Ley N.º 8968). Procuraduría General de la República. https://www.pgrweb.go.cr/DOCS/NORMAS/1/VIGENTE/L/2010-2019/2010-2014/2011/1153F/DCEF7.HTML

International Organization for Standardization. (2013a). ISO/IEC 27001:2013 Information technology—Security techniques—Information security management systems—Requirements. https://www.iso.org/standard/54534.html

International Organization for Standardization. (2013b). ISO/IEC 27002:2013 Information technology—Security techniques—Code of practice for information security controls. https://www.iso.org/standard/54533.html

International Organization for Standardization. (2022a). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection—Information security management systems—Requirements. https://www.iso.org/standard/27001

International Organization for Standardization. (2022b). ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection—Information security controls. https://www.iso.org/standard/75652.html

ISO/IEC JTC 1/SC 27. (2022). Update of ISO/IEC 27002:2022 [Artículo en revista del subcomité]. https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/ISO-IEC%20JTC%201-SC%2027_N22755_SC27%20Journal%20Vol%202%20Issue%202%20(update%20Dec%202022).pdf

Poder Ejecutivo de Costa Rica. (2012). Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales (Decreto Ejecutivo N.º 37554-JP). Procuraduría General de la República. https://www.pgrweb.go.cr/DOCS/NORMAS/1/VIGENTE/D/2010-2019/2010-2014/2012/12270/ECA5D.HTML

Universidad Nacional, Escuela de Informática. (2026). Asignación: ISO 27001 y confidencialidad para administración de bases de datos, EIF402, II Ciclo 2026 [Documento del curso proporcionado por el estudiante]. Archivo local: `Asignacion-ISO27001-Confidencialidad-DBA-II-Ciclo-2026-UNA (2).pdf`.

Universidad Nacional, Escuela de Informática. (2026). Programa del curso EIF402 Administración de Bases de Datos, II Ciclo 2026 [Documento del curso proporcionado por el estudiante]. Archivo local; no se distribuye en el repositorio.

Oracle. (2021a). Oracle Database Security Guide: Configuring privilege and role authorization. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/configuring-privilege-and-role-authorization.html

Oracle. (2021b). Oracle Database Advanced Security Guide: Introduction to Oracle Advanced Security.
https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/introduction-to-oracle-advanced-security.html

Oracle. (2021c). Oracle Database Security Guide: Configuring network data encryption and integrity.
https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/configuring-network-data-encryption-and-integrity.html

Oracle. (2021d). Oracle Database Security Guide: Configuring audit policies.
https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/configuring-audit-policies.html

Oracle. (2021e). Oracle Database Reference: DBA_USERS.
https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/DBA_USERS.html

Oracle. (2021f). Oracle Database Reference: DBA_PROFILES.
https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/DBA_PROFILES.html

Oracle. (2021g). Oracle Database Reference: UNIFIED_AUDIT_TRAIL.
https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/UNIFIED_AUDIT_TRAIL.html

Oracle. (2021h). Oracle Database Reference: V$BACKUP_PIECE.
https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/V-BACKUP_PIECE.html

Oracle. (2021i). Oracle Database Reference: AUDIT_UNIFIED_ENABLED_POLICIES.
https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/AUDIT_UNIFIED_ENABLED_POLICIES.html

Oracle. (2021j). Oracle Database Backup and Recovery User's Guide: Determining the encryption status of backup pieces.
https://docs.oracle.com/en/database/oracle/oracle-database/21/bradv/reporting-rman-operations.html

Microsoft. (s. f.). Quickstart: Deploy a Python web app to Azure App Service. Microsoft Learn.
https://learn.microsoft.com/en-us/azure/app-service/quickstart-python

Microsoft. (s. f.). Use Hybrid Connections in Azure App Service. Microsoft Learn.
https://learn.microsoft.com/en-us/azure/app-service/app-service-hybrid-connections

GlobalSuite Solutions. (s. f.). Qué es la norma ISO 27002 y para qué sirve.
https://www.globalsuitesolutions.com/es/que-es-la-norma-iso-27002-y-para-que-sirve/

ANAB. (s. f.). ISO/IEC 27001:2013 and ISO/IEC 27001:2022 comparison. ANSI Blog.
https://blog.ansi.org/anab/iso-iec-27001-2013-2022-comparison/